DAY 28 | POST-READ

Security and Guardrails: Recap and Beyond

What we covered today, plus ideas to stretch your understanding.

Prepared by **Ahmed** | linkedin.com/in/ahmed-al-imaad

Part A: Summary of today

Topic	What to remember
OWASP LLM risks	Prompt injection, sensitive information disclosure, excessive agency, improper output handling, misinformation and more.
Direct injection	The user tries to override instructions in the chat.
Indirect injection	Instructions hidden in retrieved content, emails, pages or tool results.
Jailbreaks	Role play, hypotheticals, obfuscation, persistence. Recognise; do not rely on the model alone.
Defence in depth	Input checks, context tagging, instruction hierarchy, output filters, action limits.
Secrets	Never put secrets in prompts. What is not in the context cannot leak.
Output filtering	Redact PII and secrets; never pass raw output into SQL, HTML or shells.
HITL by risk	Spot checks, review before send, approve every action.
Responsible AI	Fairness, transparency, privacy, accountability, safety, human oversight.

Part B: Going beyond today

1. Moderation APIs and safety classifiers

Providers offer moderation endpoints and safety classifiers that flag harmful content. Combine them with your own business rules; neither alone is enough.

2. Red teaming

Before launch, a team tries to break the system on purpose, with written permission and a clear scope. Findings become test cases that run on every release.

3. Data residency and privacy law

Customers in India and Japan may need data to stay in-country and to follow laws such as India's Digital Personal Data Protection Act and Japan's Act on the Protection of Personal Information. Confirm requirements with the customer's legal and security teams.

4. Counterfactual fairness tests

Run the same request with only a name, gender or location changed. Differences in outcome that are not justified by the task are a red flag to investigate.

5. Incident response for AI

Have a plan: how to switch features off, who is notified, how to review logs, and how to tell affected users. Practise it before you need it.

Part C: Check yourself

- Why is indirect injection especially dangerous for RAG and agents?
- Why is removing secrets from the prompt better than telling the model not to reveal them?
- Name the five guardrail layers.
- Which actions in a support bot need human approval?
- How would you measure false alarms in an injection detector?

Part D: Practice ideas for tonight

- Add five new attack prompts and five tricky benign prompts to the red-team suite.
- Add an output check that blocks answers containing internal URLs.
- Write a one-page AI incident response checklist for your capstone.

Coming up on Day 29: evaluating GenAI systems: relevance and faithfulness, RAG evaluation, and bias and hallucination analysis.

Otsukaresama deshita (お疲れ様でした): thank you for your hard work today